



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Red Heron Gitea RCE Repository Theft Campaign Daily Review 2026-09-16

Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-09-16
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Red Heron Gitea RCE Repository Theft Campaign Daily Review 2026-09-16 - Threat Intelligence Report
Published: 2026-09-16 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review and Confidence
4. Threat / Campaign Overview
5. Tactics, Techniques, and Procedures
6. Infrastructure, Indicators, and Observables
7. Sector Impact
8. Detection Engineering
9. Threat Hunting
10. Risk Assessment
11. Recommended Actions
12. References

Red Heron Gitea RCE Repository Theft Campaign Daily Review 2026-09-16

1. Executive Summary

BLUF: Public reporting says Red Heron exploited Gitea CVE-2026-60004 to steal repositories, harvest credentials, persist, and move laterally across multiple countries. This report is a finished Lost Boys Cyber daily intelligence product for 2026-09-16. Source recency was prioritized for the last 24-72 hours and expanded to 7 days or standing sector references where necessary for corroboration.

Field	Value
Daily Section	Top 5 general threat reports
Severity	Medium-High
Confidence	Medium
Primary Exposure	Self-hosted Git, DevOps, CI/CD, source-code management, and secrets-management environments.
Analyst Decision	Review controls, hunt telemetry, and update watchlists/playbooks

2. Intelligence Requirements

Requirement	Answer
What changed?	Public reporting says Red Heron exploited Gitea CVE-2026-60004 to steal repositories, harvest credentials, persist, and move laterally across multiple countries.
Who should care?	Self-hosted Git, DevOps, CI/CD, source-code management, and secrets-management environments.
What should analysts do today?	Validate exposure, run hunts, and review third-party/control exceptions

3. Source Review and Confidence

#	Source	URL	Role
1	The Hacker News Red Heron Gitea campaign	https://thehackernews.com/2026/09/red-heron-exploits-gitea-rce-to.html	Current news trigger
2	Gitea security advisories	https://github.com/go-gitea/gitea/security/advisories	Vendor/GitHub advisory source
3	CISA secure by design guidance	https://www.cisa.gov/securebydesign	Control reference
4	MITRE ATT&CK software development compromise techniques	https://attack.mitre.org/	Technique mapping

Confidence is Medium. This product avoids unverified attribution and treats vendor/news reporting as operational cues pending internal validation.

4. Threat / Campaign Overview

The selected reporting indicates a defender-relevant pressure point: Public reporting says Red Heron exploited Gitea CVE-2026-60004 to steal repositories, harvest credentials, persist, and move laterally across multiple countries. The likely operational pattern is not a single IOC-only event; it is a class of behavior that combines exposure management, identity control, endpoint visibility, and rapid triage.

Signal	Why It Matters	Collection
Gitea CVE-2026-60004	Primary analytic pivot for this topic	SIEM/EDR/vulnerability/source logs
repository theft	Secondary behavior or exposure clue	Identity, proxy, EDR, cloud logs
CI/CD credential exposure	Triage and watchlist value	Case notes, watchlists, alert enrichment

5. Tactics, Techniques, and Procedures

Tactic	Technique / Behavior	Defensive Note
Initial Access	Phishing, exploit delivery, exposed remote access, or supplier access	Prioritize high-value users/assets and vendor paths
Execution	Scripted execution, payload staging, or malicious automation	Monitor parent/child process chains and command-line anomalies
Credential Access	Token, password, or session theft where relevant	Review impossible travel, risky sign-ins, OAuth app grants
Command and Control	Reused infrastructure, cloud services, or remote-management tooling	Enrich DNS/proxy/EDR network events and block known-bad only after validation

6. Infrastructure, Indicators, and Observables

Observable	Type	Action
Gitea CVE-2026-60004	Observable / analytic pivot	Validate in SIEM, EDR, vulnerability, and ticketing systems
repository theft	Observable / analytic pivot	Validate in SIEM, EDR, vulnerability, and ticketing systems
CI/CD credential exposure	Observable / analytic pivot	Validate in SIEM, EDR, vulnerability, and ticketing systems

No hard atomic IOCs are asserted unless present in the cited public sources. Treat these entries as observables and hunting pivots.

7. Sector Impact

Segment	Operational Relevance	Likely Exposure Path	Defender Action
Enterprise IT	Credential theft and endpoint compromise can accelerate lateral movement	Identity, email, browser, cloud, endpoint	Validate MFA, EDR coverage, and privileged access controls

Security operations	Current reporting creates new detection and watchlist priorities	SIEM/EDR/proxy/email logs	Run hunts and add source-specific pivots
Third parties	Supplier or managed-service exposure can bypass direct perimeter controls	Vendor access, SaaS, shared tooling	Review contractual notifications and access paths

8. Detection Engineering

<pre>DeviceProcessEvents where Timestamp > ago(7d) where ProcessCommandLine has_any ("powershell", "rundll32", "mshta", "regsvr32", "curl", "bitsadmin", "rmm", "screenconnect", "anydesk") summarize Events=count(), Hosts=dcount(DeviceName), Samples=make_set(ProcessCommandLine, 10) by FileName, InitiatingProcessFileName order by Events desc</pre>
<pre>SigninLogs where TimeGenerated > ago(7d) where ResultType != 0 or RiskLevelDuringSignIn in ("medium", "high") summarize Failures=count(), Users=dcount(UserPrincipalName), IPs=make_set(IPAddress, 20) by AppDisplayName, ConditionalAccessStatus order by Failures desc</pre>
<pre>title: Daily Threat Review Suspicious Remote Tool Or Script Chain status: experimental logsource: product: windows category: process_creation detection: selection_tools: CommandLine contains: - 'screenconnect' - 'anydesk' - 'teamviewer' - 'powershell -enc' - 'rundll32' condition: selection_tools fields: - UtcTime - Image - ParentImage - CommandLine - User level: medium</pre>

9. Threat Hunting

<pre>DeviceNetworkEvents where Timestamp > ago(14d) where RemoteUrl has_any ("pastebin", "githubusercontent", "workers.dev", "ngrok", "trycloudflare", "duckdns", "filen", "mega") summarize Events=count(), Hosts=dcount(DeviceName), Urls=make_set(RemoteUrl, 25) by InitiatingProcessFileName order by Events desc</pre>
<pre>index=endpoint earliest=-14d (process_name IN ("powershell.exe","rundll32.exe","mshta.exe","regsvr32.exe") OR command_line="*screenconnect*" OR command_line="*anydesk*") stats count dc(host) as hosts values(command_line) as sample_commands by parent_process_name process_name user sort - count</pre>

Hunt intent: identify behavior classes related to this daily item, then pivot through affected business units and source-specific observables.

10. Risk Assessment

Risk	Rating	Rationale
Operational disruption	Medium-High	Dependent services, identity, or endpoints can affect business continuity
Data exposure	Medium	Credential/session compromise and supplier paths can expose sensitive data
Detection gap	Medium	Many signals require cross-domain telemetry correlation

11. Recommended Actions

Priority	Action	Owner
P1	Run the included hunts against the last 7-14 days	SOC / Detection Engineering
P2	Validate control exceptions and internet/vendor exposure	Vulnerability / IT Ops
P3	Add this topic to daily watchlists and case-triage notes	CTI / SOC Lead

12. References

- [1] The Hacker News Red Heron Gitea campaign: <https://thehackernews.com/2026/09/red-heron-exploits-gitea-rce-to.html>
- [2] Gitea security advisories: <https://github.com/go-gitea/gitea/security/advisories>
- [3] CISA secure by design guidance: <https://www.cisa.gov/securebydesign>
- [4] MITRE ATT&CK software development compromise techniques: <https://attack.mitre.org/>